

# Navigating Risk and Rewards

## Automated Security Playbook Collaboration Framework in Critical Infrastructure

Thesis author: Dodzi Kwasi Nuhoho (s240054) · February 2026

MSc Eng, Communications Technologies and System Design, Technical University of Denmark

Supervisors: Sarah Renée Ruepp (DTU Electro) · Michael Dreyer Kollemorten (TDC NET)

### The thesis at a glance

**Problem.** Mobile Network Operators (MNOs) are critical national infrastructure, targeted by well-resourced, often state-sponsored actors who exploit telecom-specific protocols such as SS7 and Diameter. Yet the sector enjoys far less community threat-sharing than mainstream enterprise IT, and the sharing that does exist is mostly diagnostic (indicators and techniques) rather than operational (what to actually do about them).

**Question.** Can response knowledge be shared as machine-readable, vendor-agnostic security playbooks using the OASIS CACAO v2.0 standard, and what risks, rewards and barriers come with automating and sharing them across operators?

**Approach.** A qualitative, three-phase study: a literature review, a semi-structured interview with a manager and two security analysts at TDC NET, and a hands-on workshop with about 12 analysts, supplemented by the author's own experiments converting and generating CACAO playbooks with an LLM.

**Core finding.** Practitioners unanimously expect automation to lower detection and response times (MTTD/MTTR), but external sharing is held back mainly by *trust*, compounded by a lack of reciprocity and the fear of revealing internal defences.

**Contribution.** A *Decentralized Sharing Model* built on federated MISP instances, in which trade associations publish playbooks on behalf of contributors (functional anonymity) and a community feedback and rating loop establishes credibility over time.

## 1. Introduction and Motivation

The thesis opens with the fundamental asymmetry of information security: an attacker needs only one successful vector (malware, a software flaw, phishing, an insider), while a defender must close every one of them, continuously. Management standards such as ISO/IEC 27001 exist to impose structure on defence, but they only work when their controls are applied consistently. The author argues that security playbooks are the practical instrument for that consistency.

Defenders already collaborate by exchanging threat intelligence, but what they exchange is largely diagnostic data that still has to be interpreted by a human before anything happens. That leaves a gap between detection and execution, and different interpretations lead to inconsistent incident handling. The thesis proposes closing this gap by sharing standardised, step-by-step response logic in the form of automated playbooks, with MNOs as the focus because of their role in national and economic security.

Six research questions frame the work:

| RQ  | Research question                                                                                                                                         |
|-----|-----------------------------------------------------------------------------------------------------------------------------------------------------------|
| RQ1 | What metrics define a good playbook under ISO/IEC 27001, and how accurately can playbooks be transformed from human-readable to machine-readable formats? |
| RQ2 | How will playbooks behave under failure scenarios?                                                                                                        |
| RQ3 | What factors influence the sharing and importing of playbooks via open-source platforms?                                                                  |
| RQ4 | How do SOC analysts perceive automated playbooks running in the network?                                                                                  |
| RQ5 | How well will automated playbooks scale across the infrastructure?                                                                                        |
| RQ6 | What is the optimal balance between human oversight and machine autonomy?                                                                                 |

*The author also discloses that an AI agent built on Google Gemini was used to polish grammar and academic tone, without altering ideas or argument; the configuring prompt is reproduced in the appendix.*

## 2. Playbooks in Information Security

### 2.1 Definition and role

Terms such as playbook, runbook, response plan and SOP are often used interchangeably. The thesis adopts the common ground between the OASIS definition and that of Schlette et al.: a playbook is a structured workflow of discrete steps describing a security process or procedure, which may be triggered manually, periodically or automatically.

Within ISO/IEC 27001, playbooks primarily serve **Clause 8 (Operation)**, turning the risk-treatment decisions made in Clause 6 (Planning) into concrete actions. They directly support Annex controls for threat intelligence (5.7), incident management planning and preparation (5.24) and monitoring (8.16), and their repeatability also eases audits. For organisations not yet ready for full certification, the **Capability Maturity Model Integration (CMMI)** offers a way to measure process maturity across five levels: Initial, Managed, Defined, Quantitatively Managed and Optimizing. Playbooks typically lift an organisation to Levels 2 and 3; an explicit aim of the thesis is to explore how they could help reach Levels 4 and 5, where processes are measured statistically and improved continuously.

### 2.2 Evolution of playbooks

Playbooks have moved from printed binders to PDFs and slides, then to wikis with embedded links, and on to flowcharts and BPMN diagrams that improved situational awareness under time pressure. As individual steps proved automatable (for example, pushing a malicious IP to a firewall), **runbooks** appeared: executable scripts for single tasks. Runbooks, however, lack a view of the whole response. Expressing the entire playbook in machine-readable formats such as JSON or YAML solved that, but vendors did so in proprietary formats, locking playbooks into specific tool ecosystems. Sharing then only works among organisations using the same tools, which is the open problem the thesis sets out to address.

### 2.3 Persistent challenges

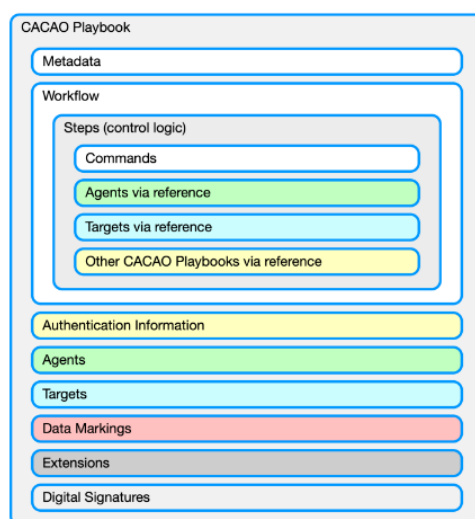
Drawing on Schlette et al.'s analysis of more than 1,200 playbooks, the thesis notes that community playbooks rarely work out of the box because they ignore local context such as GDPR obligations, infrastructure and tooling. The reverse problem is equally hard: an organisation's tailored playbook

cannot be shared without sanitisation, and sanitising it strips out exactly the context that made it useful. This tension between usefulness and shareability runs through the rest of the thesis.

## 2.4 The CACAO specification

OASIS chartered the CACAO (Collaborative Automated Course of Action Operations) Technical Committee in 2019 to create a machine-readable, JSON-based, vendor-neutral format for playbooks. Version 1.0 became an OASIS Standard in 2022, and the thesis works with version 2.0. The motivation is interoperability and speed: encoding triggers, decision logic, actions and integrations in one common language so that proven responses can be shared and executed across SOAR, SIEM and other tools without vendor lock-in.

CACAO defines eight playbook types: attack, detection, investigation, engagement, mitigation, notification, prevention and remediation. A playbook consists of metadata, a workflow of steps, and commands attached to those steps. Commands are the key to interoperability because they can carry Sigma detection rules, OpenC2 response actions, scripts or Jupyter notebooks. Steps can reference agents, targets and even other playbooks, which makes playbooks modular. Authentication information, **data markings** (typically the Traffic Light Protocol: CLEAR, GREEN, AMBER, RED) and **digital signatures** govern who may see a playbook and whether it can be trusted as authentic.



Structure of a CACAO playbook (reproduced from the thesis, Figure 2.3, after OASIS).

## 2.5 From legacy to machine-readable

Converting the large stock of human-readable playbooks by hand is impractical. Gurabi et al. showed that LLMs, guided by structured prompt engineering, syntax validation and iterative refinement, can translate legacy playbooks into CACAO while keeping hallucinations in check. Fidelity matters because these playbooks are meant to execute: an error that alters the workflow logic can produce a wrong response in a live environment.

## 3. Operational Security in Mobile Networks

The thesis situates SOC work within the **NIST Cybersecurity Framework** and its six functions, noting that SOC activity lives mainly in Detect and Respond, and sometimes Recover.

| Function | Focus      | Aim                                                    |
|----------|------------|--------------------------------------------------------|
| Govern   | Strategy   | Establish roles, policies and risk-management strategy |
| Identify | Inventory  | Map hardware, software, services and other assets      |
| Protect  | Prevention | Implement safeguards that prevent or reduce risk       |
| Detect   | Visibility | Monitor and analyse events for suspicious activity     |
| Respond  | Action     | Contain the impact of incidents                        |
| Recover  | Resilience | Restore systems to normal operation                    |

A SOC relies on layered tooling (firewalls, IDS, EDR for endpoints, NDR for network traffic, ticketing, SIEM and SOAR) to achieve defence in depth: if an attacker blinds an endpoint, network telemetry can still raise the alarm. Alerts converge in the SIEM's single pane, user reports arrive via ticketing, and a single point of contact escalates genuine threats into an incident process that may involve legal and executive stakeholders. Every step is documented in a case management system. The roles involved include SOC managers, analysts, engineers, threat hunters and forensic investigators.

### Why MNOs have it harder

- **Alert fatigue at scale:** large, distributed networks spanning IT and operational technology, including core network elements, produce huge volumes of alerts, many of them benign.
- **An expanding attack surface:** 5G features such as network slicing and edge computing decentralise the architecture and multiply entry points.
- **Regulatory clocks:** under the EU NIS2 Directive, a significant incident requires an initial notification within 24 hours and an intermediate report within 72 hours, while attacker dwell-to-impact times keep shrinking.
- **Niche protocols:** SS7 and Diameter receive little attention in public threat intelligence compared with ubiquitous enterprise protocols such as SMB.
- **Sophisticated adversaries:** state-backed groups with the resources to develop zero-day exploits tailored to mobile infrastructure.

## 4. Automation and Orchestration

The thesis distinguishes **automation**, which performs individual repetitive tasks without human intervention (script-based, event-driven or scheduled), from **orchestration**, which coordinates many automated tasks across systems into an end-to-end workflow. A phishing example illustrates the difference: automation searches thousands of mailboxes for a subject line; orchestration chains the SIEM alert, a web proxy block, a VirusTotal reputation check and an enterprise-wide mailbox clean-up through APIs, then hands the analyst a completed report.

LLMs and emerging agentic AI can generate scripts and detection logic and may eventually run orchestration themselves, but because they need access to sensitive data, the author advises large-scale use only with on-premises or locally hosted (ideally open-source) models. SOAR platforms are the natural execution engine, yet their proprietary playbook formats mean a Splunk SOAR playbook cannot simply move to a competing product.

The trade-offs are summarised in a benefits-and-risks matrix:

| Dimension   | Benefit                                      | Risk                                                |
|-------------|----------------------------------------------|-----------------------------------------------------|
| Speed       | Reduces MTTD and MTTR                        | One faulty step cascades at machine speed           |
| Scale       | Handles thousands of alerts per day          | Requires constant maintenance and tuning            |
| Consistency | Standardised, predictable execution          | Static rules break when attackers change tactics    |
| Integration | Links all essential tools for rapid response | High complexity and cost to build and maintain SOAR |

Automation also cannot replicate human judgement in novel situations: signature- and heuristic-driven systems struggle with zero-days and polymorphic malware, and poorly filtered event-driven detection can itself become a source of alert fatigue.

## 5. Collaborative Defence and Information Sharing

The 2021 **FluBot** campaign anchors the chapter. This Android spyware spread by SMS phishing and used a domain generation algorithm that produced fresh command-and-control domains every month, defeating simple blocklists. Stopping it required reverse-engineering the algorithm, close cooperation with MNOs and a law enforcement operation spanning 11 countries: a clear case of a threat beyond any single organisation.

### 5.1 Threat intelligence

STIX provides a standard JSON representation of threat intelligence and TAXII transports it over HTTPS through Collections (hosted repositories) and Channels (push to subscribers), so that feeds flow directly into tools such as SIEMs. The thesis describes three tiers:

- **Tactical** intelligence consists of indicators of compromise such as IPs, domains and hashes. It is fast to act on but short-lived (roughly 30 days of relevance), and attackers evade it by rotating infrastructure or using polymorphism.
- **Operational** intelligence covers threat actors and their tactics, techniques and procedures, catalogued in frameworks such as MITRE ATT&CK and, for telecoms, **Bhadra**, which lists sector-specific techniques such as SIM-based compromise. It is durable because changing TTPs is costly for the adversary; groups such as Salt Typhoon illustrate its relevance to telecoms.
- **Strategic** intelligence covers high-level trends, geopolitics and regulation, consumed by leadership through trade associations and industry forums.

The author places these in a hierarchy: indicators form the base, TTPs add operational context, and playbooks sit on top as containers that integrate both into actionable response.

### 5.2 Sharing platforms

- **MISP**, the open-source threat intelligence platform, organises data into Events, Attributes and Objects, supports tags, taxonomies and community-based sharing, and already hosts a set of playbooks as Jupyter notebooks that use the PyMISP API.
- **GitHub** hosts MISP's playbooks and many human-readable ones, including Société Générale's incident response methodologies used later in the thesis.

- **Mattermost**, a self-hostable collaboration platform, combines Channels for discussion, Boards for task tracking and its own Playbooks feature, which can spin up an incident channel, checklists and calls while leaving a full audit trail.

### 5.3 Requirements for collaborating through playbooks

From Gurabi et al.'s work on sharable playbooks, the thesis adopts four requirements: a **standardised machine-readable vocabulary**; **privacy and confidentiality**, including stripping sensitive data and possibly anonymising publishers; **visualisation**, since responders prefer to see the flow; and **usability**, which conflicts with privacy. The proposed compromise is to apply TLP markings to individual steps and resources rather than to the whole playbook.

## 6. Research Methodology

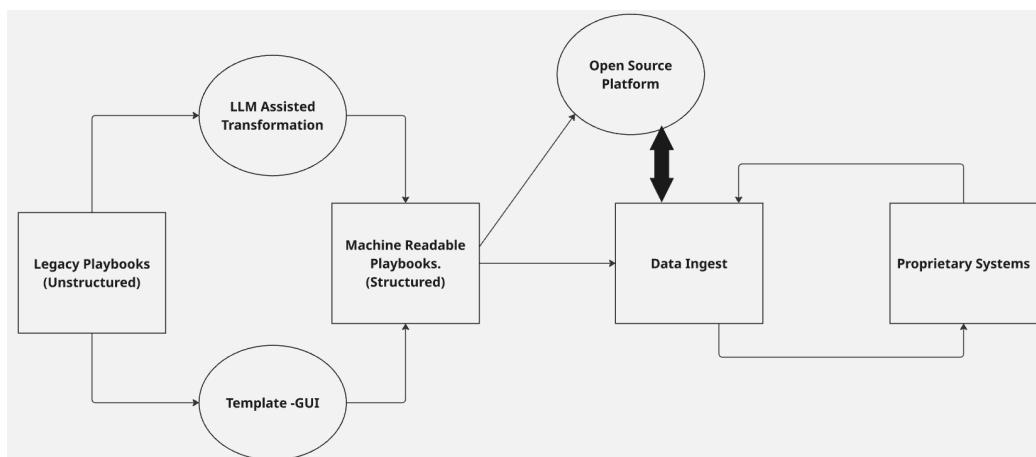
The study is qualitative, aiming to capture expert judgement and context rather than measurements.

| Phase             | Method                                                            | Participants                  | Purpose                                                                  |
|-------------------|-------------------------------------------------------------------|-------------------------------|--------------------------------------------------------------------------|
| I. Exploration    | Literature review (DTU Findit, Google Scholar, industry sources)  | —                             | Identify gaps; established CACAO as the leading vendor-agnostic standard |
| II. Investigation | Semi-structured, in-person interview (about 1 hour)               | 3 (1 manager, 2 analysts)     | Gather primary industry insight at TDC NET                               |
| III. Validation   | Practical workshop with questionnaire and LLM playbook generation | About 12 analysts in 4 groups | Validate findings and test feasibility of generating CACAO playbooks     |

The author is candid about limitations. The original goal of executing a CACAO playbook in a production or simulated SIEM environment was dropped: the time frame was too short, CACAO has little production adoption yet, and the SIEM/API integration effort was significantly underestimated. The focus therefore shifted to playbook *generation* and to the conditions for *sharing*, a shift reinforced by the interview finding that the main obstacles are organisational sentiment and risk perception rather than technology. The interview sample (three people at one company) is acknowledged as too small to generalise, although participants believed their views reflect the wider community.

## 7. Exploration and Validation: Findings

The preliminary concept links three stages: legacy playbooks are converted to structured CACAO playbooks, either through an LLM or a GUI template; the result is then published to an open-source sharing platform and/or ingested into an organisation's own security systems.



Preliminary workflow from legacy to shared, machine-readable playbooks (thesis Figure 7.1).

## 7.1 Transforming a legacy playbook

As a test case, the author converted Société Générale's human-readable phishing playbook (IRM-16) to CACAO. The toolchain combined Docker, ChatGPT, **SOARCA** (an open-source orchestrator that ingests, validates and executes CACAO playbooks over HTTPS, SSH and OpenC2) and **CACAO Roaster** (a web editor and visualiser). Building the playbook in Roaster's GUI was possible but slow, so the LLM did the heavy lifting: it was given the CACAO schema (retrieval-augmented generation) and a persona prompt asking it to act as an expert and produce a SOARCA-importable playbook.

The resulting JSON imported successfully and rendered as a flowchart. Two observations stand out. First, Roaster's import acts as a **syntax validator** (non-conforming playbooks are rejected) but performs **no semantic validation**, so it cannot tell whether the logic is correct. Second, the graphical view is valuable for both the analyst following the steps and the author checking for LLM hallucinations.

## 7.2 What practitioners said

**Why playbooks matter.** The manager valued playbooks for standardising detection and response so that quality does not depend on who is on shift; a junior analyst facing an alert late at night can be overloaded without a clear procedure. He also observed that many organisations still lack comprehensive playbook libraries, and that simply getting them written, in any format, is the essential first step.

**Expected impact.** All workshop groups (100%) answered yes both to automated playbooks lowering MTTD and MTTR and to shared playbooks among MNOs doing the same, with conditions: full automation and control of the workflow (Group 2), aligned schemas and tags between operators (Group 2), and low translation overhead to fit local tooling (Group 3).

**Trust in a shared automated playbook, by source.** Colour indicates the level of trust expressed (green: high; amber: conditional; red: very low).

| Group | Colleague        | MNO in Denmark                        | MNO outside Denmark                   | Internet            |
|-------|------------------|---------------------------------------|---------------------------------------|---------------------|
| 1     | Yes              | Depends on the MNO                    | Depends on the MNO                    | No                  |
| 2     | Yes              | Higher trust, but still needs vetting | Lower than Danish MNOs; needs vetting | Requires vetting    |
| 3     | Yes              | Some trust, not full; evaluate        | Some trust, not full; evaluate        | Should be evaluated |
| 4     | Should be vetted | Should be vetted                      | Should be vetted                      | Should be vetted    |

Trust clearly decreases with social distance, from colleagues to domestic operators to foreign operators to the open internet. Group 4 is an outlier with a zero-trust stance toward every source, which the author attributes to the differing roles of the analysts surveyed.

**Barriers to sharing** identified in the interview:

- **Lack of trust**, which is more easily built in small communities with direct personal contact.
- **Fear of exposure**: a playbook reveals internal processes and tooling, a potential blueprint for attackers if the source can be identified.
- **No reciprocity**: sharing without feedback or mutual benefit feels like wasted effort, so resources go back to internal work.
- **No mandate**: there is currently no regulatory requirement to share playbooks; analysts expect that a mandate (for example, under NIS2) would turn the question into one of compliance.

**Building on Sigma.** An analyst pointed out that Sigma rules are already widely used because they are readable YAML and translate into any SIEM query language. The author notes the two can be combined in both directions: a Sigma rule's *references* field can link to a shared CACAO playbook, so detection leads straight to a response plan, while CACAO's command object can embed Sigma rules to handle detection inside a playbook. Doing so lowers the learning curve for practitioners.

### 7.3 Workshop: generating playbooks from everyday tasks

Unlike Gurabi et al., who converted legacy documents, the workshop generated playbooks directly from routine work. One exercise took the NVD entry for **CVE-2025-5777 (CitrixBleed 2)** and asked an LLM, given the CACAO v2 specification, to produce a playbook identifying signs of exploitation with strict syntax and semantic fidelity. The output included all mandatory fields and plausible hunting signals, but it had clear weaknesses:

- Every command was of type *manual*, so analysts would still run the SIEM queries themselves, even though CACAO supports programmatic execution via HTTP API, SSH or OpenC2.
- *target\_definitions* was empty despite implicit targets such as the SIEM and NetScaler logs.
- The playbook covered detection and investigation only; escalation was mentioned but neither automated nor linked to a containment playbook.

A follow-up prompt added response steps but kept the same structural flaws. Other workshop participants, however, obtained better results, including properly defined targets, through more sophisticated and iterative prompting. The author concludes, in line with Gurabi et al., that output quality



depends heavily on prompt engineering, and that well-configured AI agents could generate such playbooks reliably.

## 8. Discussion

**Internal versus external use.** Building playbooks for internal automation meets little resistance, because nothing sensitive leaves the organisation; their value lies in maturity and compliance. That also explains why most playbooks stay human-readable, with scripts covering only repetitive tasks, and why consistency can vary between teams in the same organisation. For RQ4, the author reflects that the real question is orchestration rather than simple automation: analysts favour orchestration provided that failure handling and oversight are addressed. RQ5 could not be tested without a production deployment, but CACAO's modular design (calling other playbooks and agents) suggests it can scale horizontally.

**Trust is the root cause.** Lack of reciprocity and standardisation are real obstacles to external collaboration, but the author sees them as symptoms of a deeper lack of trust. The reluctance is rational: organisations weigh the risk of exposure against substantial internal benefits they already enjoy. TLP markings help, but stripping data for privacy can make a playbook less usable, and anonymity by itself does not create trust, since the survey shows unknown publishers are treated like random internet sources. Anonymous contributions therefore need a way to become verifiable.

**The recipient's burden.** Adapting a generic CACAO playbook to local tools takes time. For a threat the analyst already knows, the gain may be small; for an unfamiliar one, an expert-defined process can substantially shorten discovery time. The author calls for a **unified process vocabulary** within CACAO plus vendor mapping layers that translate it into tool-specific commands, much as Sigma is translated into SIEM query languages.

### Answers to the failure and oversight questions (RQ2, RQ6)

On failure, playbooks should halt all actions and record their state immediately, and apply rate limiting to stop runaway loops and cascading errors. For oversight, the balance comes from **mandatory breakpoints**: checkpoints where an analyst must approve actions, particularly those touching sensitive data or critical infrastructure, before automation continues.

**Quality metrics (RQ1).** A playbook must first conform to the CACAO specification (schema, mandatory fields, workflow logic, integrity signing). For alignment with ISO/IEC 27001 it must also be documented, effective, tested and continually improved. The thesis proposes six metrics:

| Metric                  | What it means                                                                                    |
|-------------------------|--------------------------------------------------------------------------------------------------|
| Scenario coverage       | Handles multiple scenarios, including edge cases and failure states (rate limiting, breakpoints) |
| Operational efficiency  | Measurably reduces MTTD and MTTR                                                                 |
| Regulatory compliance   | Execution aligns with applicable legislation                                                     |
| Detection accuracy      | For detection playbooks, a low false-positive rate                                               |
| Automation success rate | A high share of tasks completed without manual intervention                                      |
| Audit                   | Automatically documents every action taken                                                       |

On transformation accuracy, the author finds that chatbots can generate CACAO playbooks with high accuracy when prompted well, and can now work straight from advisories and vulnerability records, which makes legacy documents less essential as input. The remaining effort lies in validating that the workflow does exactly what is intended; tools such as CACAO Roaster check syntax and structure, and analysts value the graphical view for explaining actions to management.

## 9. Recommendation: A Decentralized Sharing Model

To tackle the trust problem, the thesis proposes a model for the MNO security community built on three components: decentralised sharing, anonymity and credibility.

### 9.1 Decentralised sharing via MISP

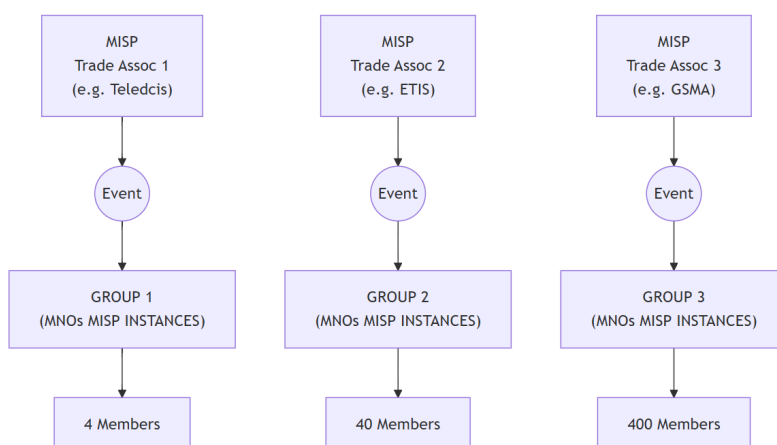
MNOs that belong to trade associations such as the GSMA synchronise their own MISP instances with the association's. A playbook is published as a MISP event tagged for the verified community, and members receive it and any later updates. There is no central repository: every organisation keeps its own instance and local control of its data, and any member can act as a source, although publishing directly reveals the contributor's identity.

### 9.2 Functional anonymity

The trade association acts as an intermediary that publishes on the contributor's behalf, either after its own technical review or by relying on the contributor's competence, with community feedback as a further safeguard. Anonymity depends on the size of the pool, as the thesis illustrates with three hypothetical associations:

| Association (example) | Scope                   | Members | Chance of identifying the contributor |
|-----------------------|-------------------------|---------|---------------------------------------|
| Teledcis              | National (e.g. Denmark) | 4       | 25%                                   |
| ETIS                  | Continental (Europe)    | 40      | 2.5% (implied by the model)           |
| GSMA                  | Global                  | 400     | 0.25%                                 |

A pool of two offers no anonymity, since the other member knows the source by elimination; anything above two is considered workable because these are private, trusted forums. Operators can start sharing in a small, high-trust national group and move to larger, global forums as their confidence grows.

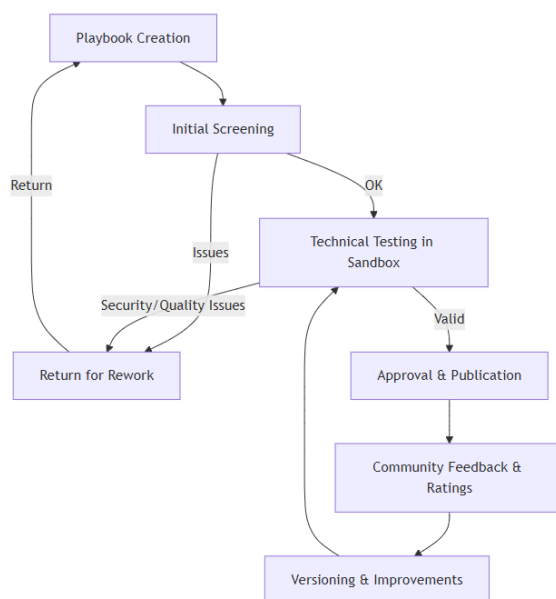


Anonymity depends on the size of the participant pool (thesis Figure 8.2).

### 9.3 Credibility through feedback

Once published, a playbook's worth is established by its recipients through qualitative feedback (for example, suggesting better rate limiting or breakpoints) and simple quantitative ratings such as stars or upvotes. Ratings lower the barrier for analysts who hesitate to write comments, and together they make the repository self-correcting: a playbook is valued for proven efficacy rather than for its author's identity.

The playbook lifecycle runs from creation, through validation against the CACAO schema (syntax and semantics), to sandbox testing in a production-like environment, with any failure sending it back for rework. Approved playbooks go to the trade association for optional screening and publication as MISP events, then enter a continuous cycle of ratings, feedback and versioning; major changes are re-tested in the sandbox. **Mattermost** is proposed as a private space where associations and operators can discuss and resolve issues before dissemination, which can also foster the exchange of strategic intelligence.



*Playbook lifecycle within the decentralised sharing model (thesis Figure 8.3).*

End to end, MNO A detects an attack and writes a CACAO playbook; anonymisation and vetting follow in either order depending on the arrangement with the association; the approved playbook is published to the federated MISP repository; other operators pull it into their SIEM or SOAR; and they return feedback, votes and comments that keep the resource credible.

## 10. Conclusion and Future Work

The thesis concludes that collaborative, automated playbooks promise real operational gains for MNOs, above all lower MTTD and MTTR, but that trust, not technology, is the main barrier to collective action. Once trust concerns are addressed, the author expects practitioners to drive CACAO adoption. A decentralised model that combines sharing, vetting, peer review and anonymity, and gives participants a say in its governance, is judged best placed to build that trust.

| Research questions                           | Resolution in the thesis                                                                                                                                                                                                                                                    |
|----------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| RQ1 & RQ5<br>Standardisation and scalability | The CACAO schema preserves semantic accuracy and supports ISO/IEC 27001 metrics such as auditability and efficiency; decoupling process logic from vendor commands lets playbooks scale across diverse infrastructure (argued theoretically, not yet tested in production). |
| RQ2 & RQ6<br>Operational oversight           | Rate limiting and mandatory breakpoints prevent cascading failures while keeping humans in control at critical decision points.                                                                                                                                             |
| RQ3 & RQ4<br>Sharing and perception          | Analysts value the internal efficiency of automation, but external collaboration is held back by lack of reciprocity and organisational trust.                                                                                                                              |

#### Directions for future research proposed by the author:

- Sharing the prompts, documents and configurations used to set up playbook-generating AI agents, so that collaborators produce functionally similar playbooks that still pass through the decentralised model.
- Federated learning, in which collaborators train models locally and average their weights without exchanging sensitive data; the trust implications of this require dedicated machine-learning research.
- Empirical measurement of latency and resource consumption when CACAO playbooks run across multiple nodes in production, to demonstrate scalability.

#### Key takeaways

- CACAO v2.0 offers a credible, vendor-neutral way to share executable response logic, with TLP markings and digital signatures built in.
- LLMs can already produce schema-valid CACAO playbooks, but validation tools check syntax only; semantic correctness, automation depth and target definitions still depend on skilled prompting and human review.
- Practitioners see clear value in automation, but will only adopt shared playbooks from sources they trust, and will only share if they get something back.
- The proposed MISP-based federation, with association-mediated anonymity and community ratings, is designed to turn anonymous contributions into trusted, continuously improved shared assets.
- The evidence base is qualitative and small (one operator: three interviewees and about 12 workshop participants), and the model has not yet been deployed or tested, so the conclusions are best read as well-grounded proposals.